Multi-Tenant E-Commerce SaaS Architecture & API Specification

Complete Production Reference (Phases 0–5) • Core Engine, Database Schemas, Security Isolation & Endpoint Catalog

`.NET 8 Clean Architecture` `PostgreSQL 16 + RLS` `Redis 7.2 Cache` `Cloudflare R2 Media` `QuestPDF Vector Invoicing` `BYOK Gateways`

1. Multi-Tenant Architectural Model & 4-Layer Isolation

The platform executes a shared-database, shared-schema architecture capable of serving 10,000+ isolated tenant storefronts. Isolation is guaranteed across four sequential inspection layers:

1. **Edge Routing Middleware:** Resolves store domain via `Host` or `X-Custom-Tenant-Domain` against Redis cache in <1ms. Unregistered or suspended tenants are rejected with HTTP 404 or 403.
2. **Token Claims & Device Revocation:** `OnTokenValidated` verifies that the token's `tenant_id` claim strictly matches the current domain, and matches `SecurityStampVersion` against PostgreSQL to enforce instantaneous multi-device logout.
3. **ORM Scoping:** EF Core automatically injects `WHERE TenantId == @CurrentTenantId` across all queries. `TenantSaveChangesInterceptor` binds and verifies `TenantId` on all inserts and updates.
4. **PostgreSQL Kernel RLS:** Enforced at database engine level via `app.current_tenant` session variable and restrictive policies, preventing data leakage even on raw SQL execution.

2. Entity Relationship Diagram (ERD) & Schema Topology

The system models 13 relational entities partitioned logically by tenant. The relational map below illustrates core entity relationships, primary keys, foreign keys, and JSONB document columns:

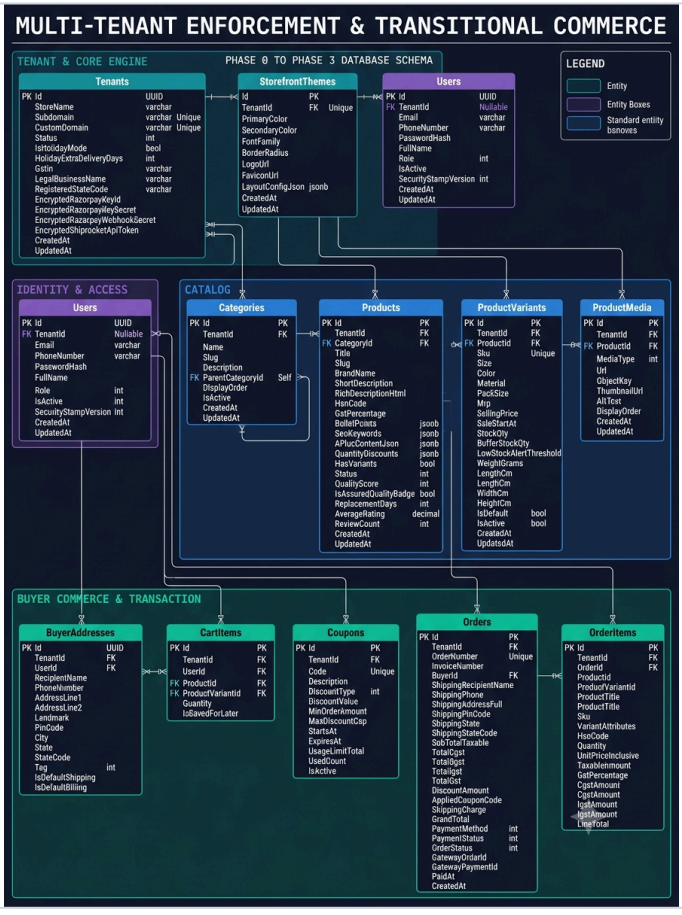


Figure 1.1: Relational Schema Topology (Tenants, Users, Catalog, Cart, Orders, Shipments, and Reviews).

3. Database Tables & Field Reference

Table Name	Primary & Foreign Keys	JSONB Columns	Indexes & Security Constraints
Tenants	PK: `Id (UUID)`	N/A	Unique on Subdomain, CustomDomain. Master table.
StorefrontThemes	PK: `Id`, FK: `TenantId`	`LayoutConfigJson`	Unique on TenantId. Cascade delete.
Users	PK: `Id`, FK: `TenantId` (Null for SuperAdmin)	N/A	Unique on `(TenantId, Email)`. RLS enforced.
Categories	PK: `Id`, FK: `ParentCategoryId`	N/A	Unique on `(TenantId, Slug)`. Self-referencing.
Products	PK: `Id`, FK: `CategoryId`	`BulletPoints`, `SeoKeywords`, `QuantityDiscounts`	Unique on `(TenantId, Slug)`. GIN FTS index active.
ProductVariants	PK: `Id`, FK: `ProductId`	N/A	Unique on `(TenantId, Sku)`. Cascade delete.
Orders & OrderItems	PK: `Id`, FK: `OrderId`, `BuyerId`	N/A	Unique on `OrderNumber`, `InvoiceNumber`.
Shipments	PK: `Id`, FK: `OrderId`	`Checkpoints`	Unique on `(TenantId, AwbNumber)`.
ProductReviews	PK: `Id`, FK: `ProductId`	`MediaUrls`	Unique on `(TenantId, ProductId, BuyerId)`.

4. Production API Endpoint Catalog (26 Endpoints)

Method & Path	Role Access	Request Payload / Parameters	Key Response & Architectural Effects
POST `/superadmin/tenants`	SuperAdmin	Store name, subdomain, customDomain, owner credentials, BYOK keys.	Provisions tenant, encrypts secrets via AES-256, seeds initial theme.
PATCH `/superadmin/tenants/{id}/status`	SuperAdmin	`{"status": 2}` (Active, Suspended, Archived)	Updates tenant state; instantly evicts Redis domain routing cache.
POST `/auth/login`	Public	`{"email", "password"}`	Returns 7-day JWT containing tenant_id, role, and security_stamp.
POST `/auth/register`	Public	`{"email", "phoneNumber", "fullName", "password"}`	Registers buyer scoped strictly to the current store tenant.
POST `/auth/logout-all-devices`	Authorized	None	Increments SecurityStampVersion, invalidating all issued sessions.
GET `/storefront/bootstrap`	Public	None	Returns store name, holiday mode status, and custom theme CSS variables.
GET `/storefront/products`	Public	`q, categorySlug, minPrice, minDiscount, inStockOnly`	PostgreSQL GIN full-text search with dynamic holiday ETA calculation.
GET `/storefront/products/{slug}`	Public	Route slug	Redis-cached PDP with variant matrix, trust signals, and stock badges.

Method & Path	Role Access	Request Payload / Parameters	Key Response & Architectural Effects
GET `/storefront/seo/products/{slug}`	Public	Route slug	Server-rendered HTML OpenGraph shell for WhatsApp/Instagram previews.
POST `/seller/products`	SellerOnly	Title, HSN, GST %, variants, media, volume discounts.	Calculates QualityScore (0–100), creates product, purges catalog cache.
POST `/seller/media/presigned-url`	SellerOnly	`{"fileName", "contentType"}`	Generates pre-signed S3/R2 PUT URL scoped to tenant storage prefix.
PATCH `/seller/inventory/{variantId}`	SellerOnly	`{"stockQty", "bufferStockQty", "lowStockAlertThreshold"}`	Updates inventory and immediately purges product PDP cache in Redis.
POST `/buyer/checkout`	Buyer	`{"shippingAddressId", "paymentMethod", "couponCode"}`	Atomic stock deduction, GST tax split, BYOK Razorpay order generation.
POST `/buyer/checkout/verify-payment`	Buyer	`{"orderId", "razorpayOrderId", "razorpaySignature"}`	Verifies HMAC-SHA256 signature against decrypted merchant secret.
GET `/buyer/orders/{id}/invoice`	Buyer/Seller	Order ID	Returns vector GST Tax Invoice PDF generated via QuestPDF in <20ms.
POST `/seller/orders/{id}/ship`	SellerOnly	`{"preferredCourierName"}`	Calculates volumetric weight, assigns AWB, marks order ReadyToShip.
GET `/seller/orders/{id}/shipping-label`	SellerOnly	Order ID	Generates 4x6 inch vector thermal barcode shipping label PDF.
POST `/webhooks/courier/tracking`	Public	`{"awbNumber", "newStatus", "location", "remarks"}`	Appends scan checkpoint and synchronizes parent order tracking status.
POST `/buyer/reviews`	Buyer	`{"productId", "rating", "title", "comment"}`	Validates purchase in orders, recalculates average rating, evicts PDP cache.
GET `/seller/analytics/dashboard`	SellerOnly	None	Computes store GMV, net revenue, GST collected, top SKUs, and low-stock alerts.

5. Test Environment Seeds & Verification State

The backend has been verified against the seeded **Urban Threads** storefront using the credentials below:

- **Tenant ID:** `b00ddadd-cf11-48d4-a90e-394add359357` • **Host:** `shop.urbanthreads.in`
- **Seller Account:** `owner@urbanthreads.in` / `StrongPassword#2026` (Role: ClientSeller)
- **Buyer Account:** `customer@gmail.com` / `BuyerPassword#2026` (Role: Buyer)
- **Verified Product:** `c619dbf6-14aa-4c2c-95fb-2cae3a011126` (Heavyweight 240GSM Oversized Tee)
- **Verified Order & AWB:** Order `ORD-20261108-6575` • AWB `AWB261111270333`